

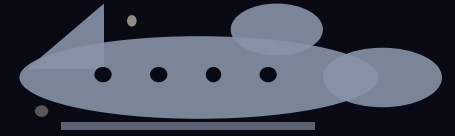
// HACKERS TEACHING HACKERS 2026 //

HTH'26

ABUSING HOLES IN CONDITIONAL ACCESS

Modern Attack Paths and How to Close Them

Brandon Colley
@techBrandon





Brandon Colley

Senior Security Consultant / TrustedSec

- 20 years experience administering and securing Entra & AD
- Speaker: DEFCON, CypherCon, TEC, BsidesKC, CornCon, HTH x3
- Identity Security Research Blogger: Petri, Quest, Practical 365, etc
- @techBrandon – LinkedIn, Twitter, GitHub
- *Fun fact: my luggage combination is 1-2-3-4-5*

// FLIGHT PLAN

TODAY'S AGENDA

ACCESS CODE: 1-2-3-4-5

01

First Things First*Setting the stage*

02

"Require MFA for Admins" — and who it misses*Attack path walkthrough*

03

Trusted locations FTW*You're doing it wrong*

04

Stacking conditions: device platforms & more*Attack path walkthrough*

05

Finding the gaps — defender's toolkit*Detection & remediation*

// SECTION 01

How Big Is It?

Sprawl, naming chaos, and the gaps that come with both.

01

HOW MANY POLICIES ARE TOO MANY?

It depends.

244

↑ from 195 (Apr 2026)

Max policies per tenant

Docs say 240 — the actual ceiling is 244.

66

templates × 11 personas

Zero Trust architecture

Add exclusion policies and the count balloons past 100s fast.

18

starter templates

Microsoft-templated baseline

What many smaller tenants actually deploy.

Whatever the count — a framework beats a free-for-all.

NAME THINGS LIKE YOU MEAN IT

A naming standard turns 200 policies into something you can audit.

PATTERN

<SN>-	<Cloud app>:	<Response>	For	<Principal>	When	<Conditions>
-------	--------------	------------	-----	-------------	------	--------------

EXAMPLE

CA01 -	Dynamics CRP:	Require MFA	For	marketing	When	On external networks
--------	---------------	-------------	-----	-----------	------	----------------------

Read it like a sentence — instantly know which app, which response, who it hits, and when.

// PREPARE THE SHIP FOR

LUDICROUS SPEED

they've gone to plaid.

NEXT ATTACK PATH →

02

// SECTION 02

MFA FOR ADMINS*

** terms and conditions apply.*

When the policy named "require MFA for admins" covers fewer admins than you think.

// THE 14-ROLE ILLUSION

"REQUIRE MFA FOR ADMINS"

Which admins, exactly?

14

Microsoft-managed CA policy

What you get if you click the template.

16

Security Defaults

A different — broader — admin set.

28+

Roles marked PRIVILEGED

What Microsoft itself flags in the portal.

NOTABLY MISSING FROM THE 14:

Intune Administrator · Directory Writers · Cloud Device Administrator · Hybrid Identity Administrator ·
more

Combined union across the three lists: 33 "privileged" roles in some way. The template covers 14.

// CASE FILE

MARCH 11, 2026

80,000 DEVICES. NO MALWARE.

TARGET

Stryker — global medical-device manufacturer.

METHOD

Compromised admin → abused Intune wipe API.

ACTOR

Handala (Iran-linked, per Unit 42).

BLAST RADIUS

~80,000 endpoints across 79 countries.

*The role that opened the door: **Intune Administrator**. Not in the 14.*

// DEMO

FINDMEACCESS

Tests authentication against multiple endpoints & apps — across many user agents.

▶ GLOBAL ADMIN**VS INTUNE ADMIN**

A terminal window titled "findmeaccess - global admin output" displays the results of a security scan. The output is a table with three columns: Resource, Accessible w/o MFA, and Accessible Client IDs. The table lists various Azure and Microsoft services, with most showing "False" for accessibility without MFA and 0 client IDs. The "msmamservice" entry is the only one showing "True" for accessibility without MFA and 38 client IDs.

Resource	Accessible w/o MFA	Accessible Client IDs
Azure Graph API	False	0
Azure Management API	False	0
Azure Data Catalog	False	0
Azure Key Vault	False	0
Cloud Webapp Proxy	False	0
Database	False	0
Microsoft Graph API	False	0
msmamservice	True	38

FINDMEACCESS

Tests authentication

▶ GLOBAL



+	Resource
+	Azure Graph API
+	Azure Management
+	Azure Data Catalog
+	Azure Key Vault
+	Cloud Webapp Proxy
+	Database
+	Microsoft Graph
+	msmamservice

FindMeAccess v3.1

```
[*] Performing test authentication
[+] Azure Graph API - Outlook Mobile - Windows 10 Chrome - Success! No MFA - Token Scope: user_impersonation
[+] Test authentication successful!
[*] Starting checks
[-] Azure Graph API - Intune MAM - Client_id not authorized for resource
[+] Azure Graph API - M365 Compliance Drive Client - Windows 10 Chrome - Success! No MFA - Token Scope: user_impersonation
[-] Azure Graph API - Loop - Client_id not authorized for resource
[+] Azure Graph API - Enterprise Roaming and Backup - Windows 10 Chrome - Success! No MFA - Token Scope: user_impersonation
[-] Azure Graph API - Editor Browser Extension - Client_id not authorized for resource
[-] Azure Graph API - Copilot App - Client_id not authorized for resource
[-] Azure Graph API - Designer App - client_assertion or client_secret required
[-] Azure Graph API - Accounts Control UI - Client_id not authorized for resource
[+] Azure Graph API - Managed Home Screen - Windows 10 Chrome - Success! No MFA - Token Scope: user_impersonation
[+] Azure Graph API - Get Help - Windows 10 Chrome - Success! No MFA - Token Scope: user_impersonation
[+] Azure Graph API - Microsoft Authentication Broker - Windows 10 Chrome - Success! No MFA - Token Scope: 62e90394-69f5-4237-9190-012177145e10
[+] Azure Graph API - Microsoft 365 Copilot - Windows 10 Chrome - Success! No MFA - Token Scope: user_impersonation
[+] Azure Graph API - Microsoft Defender Platform - Windows 10 Chrome - Success! No MFA - Token Scope: user_impersonation
[+] Azure Graph API - Microsoft Authenticator App - Windows 10 Chrome - Success! No MFA - Token Scope: user_impersonation
[+] Azure Graph API - Microsoft Defender for Mobile - Windows 10 Chrome - Success! No MFA - Token Scope: user_impersonation
[+] Azure Graph API - Microsoft Azure PowerShell - Windows 10 Chrome - Success! No MFA - Token Scope: 62e90394-69f5-4237-9190-012177145e10
[+] Azure Graph API - Microsoft Azure CLI - Windows 10 Chrome - Success! No MFA - Token Scope: 62e90394-69f5-4237-9190-012177145e10
[+] Azure Graph API - Microsoft Docs - Windows 10 Chrome - Success! No MFA - Token Scope: user_impersonation
[-] Azure Graph API - Microsoft Bing Search for Microsoft Edge - Application disabled
[+] Azure Graph API - Microsoft Bing Search - Windows 10 Chrome - Success! No MFA - Token Scope: user_impersonation
```

// LIVE DEMO

FINDMEACCESS

Same tenant, same policies — different attack surface.

GLOBAL ADMIN

VS ► INTUNE ADMIN

findmeaccess – global admin output

Resource	Accessible w/o MFA	Accessible Client IDs
Azure Graph API	False	0
Azure Management API	False	0
Azure Data Catalog	False	0
Azure Key Vault	False	0
Cloud Webapp Proxy	False	0
Database	False	0
Microsoft Graph API	False	0
msmamservice	True	38

findmeaccess – intune admin output

Resource	Accessible w/o MFA	Accessible Client IDs
Azure Graph API	True	45
Azure Management API	False	0
Azure Key Vault	True	29
Cloud Webapp Proxy	True	27
Database	True	28
Microsoft Graph API	True	50
msmamservice	True	38
Office Management	True	31

// CLOSE THE GAP

FIX THE 14

The policy that actually means what it says.



+ FOR INTUNE: Enable Multi-Admin Approval (MAA) for high-impact actions — wipe, app deploy, RBAC. Available on any Intune Plan 1.

⚠ HEADS UP: Role targeting only matches **directory-scoped** assignments. Users with the role scoped to an Administrative Unit are **not** covered.

WHO CAO2 ACTUALLY COVERS

Tier 0 + Tier 1 per the TrustedSec model — every role the policy should target.

TIER 0

Core tenant control · 9 roles

Application Administrator
Cloud Application Administrator
Conditional Access Administrator
Global Administrator
Hybrid Identity Administrator
Partner Tier2 Support
Privileged Authentication Administrator
Privileged Role Administrator
Security Administrator

TIER 1

Major service component control · 37 roles

AI Administrator	Exchange Administrator	Partner Tier1 Support
Attribute Assignment Administrator	External ID User Flow Administrator	Password Administrator
Attribute Provisioning Administrator	External Identity Provider Administrator	Power Platform Administrator
Authentication Administrator	Global Secure Access Administrator	Security Operator
Authentication Extensibility Administrator	Groups Administrator	SharePoint Administrator
Authentication Policy Administrator	Helpdesk Administrator	Skype for Business Administrator
B2C IEF Keyset Administrator	Identity Governance Administrator	Teams Administrator
Cloud App Security Administrator	Intune Administrator	Teams Telephony Administrator
Compliance Administrator	Knowledge Administrator	User Administrator
Directory Synchronization Accounts	Lifecycle Workflows Administrator	Windows 365 Administrator
Directory Writers	Microsoft 365 Backup Administrator	Yammer Administrator
Domain Name Administrator	Microsoft 365 Migration Administrator	
Dynamics 365 Administrator	On Premises Directory Sync Account	

// WHILE WE'RE OUT HERE LET'S

COMB

THE DESERT.

We ain't found shit. Yet.

NEXT ATTACK PATH →

03

// SECTION 03

TRUSTED* LOCATIONS

** trust is doing a lot of heavy lifting.*

When "inside the network" is one WiFi password — or one Airbnb — away.

WHO'S IN YOUR /16?

"Trusted location" is doing more work than you think.

BAD CIDR

Nobody's done the math.
/16 = 65,536 hosts.

WIRELESS BLEED

Guest WiFi. Contractors. The
conference room AP.

VPN SPRAWL

Commercial. Community.
Private routing. All viable.

STALE TRUST

Added once, never reviewed
— until something breaks.

REAL INCIDENTS

*APT28 breached a US target by compromising buildings across the street to reach the unprotected enterprise Wi-Fi.
— Volexity, Nov 2024 "Nearest Neighbor Attack".*

// THE ANTI-PATTERN

TRUSTED $\neq$ NO MFA

Excluding trusted locations from an MFA policy = free pass for anyone who can reach those IPs.

SIGN-IN ATTEMPT



LOCATION CHECK

NOT TRUSTED ✓

✗ TRUSTED

INTENDED

MFA REQUIRED

Policy works as expected.

ACTUAL

MFA SKIPPED

Anyone behind that IP gets in clean.

WHY THIS PERSISTS: An old way to cut MFA prompts. **Primary Refresh Tokens** on hybrid/Entra-joined devices already do that.

// FROM THE PORTAL

THE BYPASS, IN POLICY FORM

A real CA policy excluding trusted locations from an MFA grant — directly from Entra.

The screenshot shows the configuration page for a Conditional Access policy in the Microsoft Entra portal. The browser address bar shows `entra.microsoft.com` with the path `Conditional Access` and `Policy`.

Policy Details:

- Name:** BAD - Require MFA or Compliant or Trusted...
- Assignments:** Users: All users included and specific users excluded; Target resources: All resources (formerly 'All cloud apps');
- Network:** NEW. Any network or location and all trusted locations excluded.
- Conditions:** 1 condition selected.
- Access controls:** Grant: 2 controls selected.

Configuration Options:

- Control user access based on their network or physical location:** Yes (selected).
- Include/Exclude:** Include (selected), Exclude.
- Any network or location:** Selected (radio button).
- Other options:** All trusted networks and locations, All Compliant Network locations, Selected networks and locations.

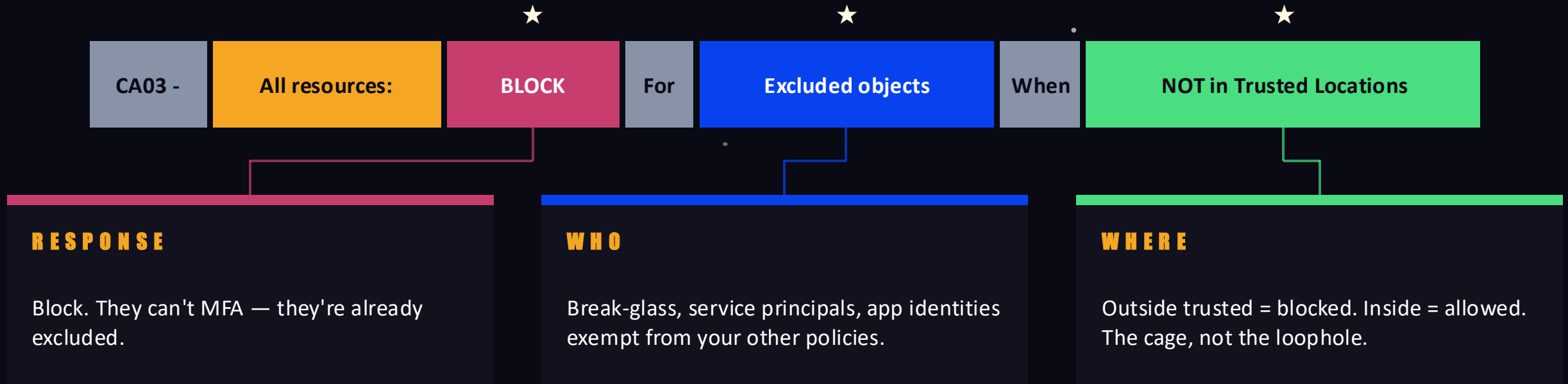
Grant Section:

- Control access enforcement to block or grant access:** Grant access (selected).
- Require multifactor authentication:** Checked (checkbox).
- Require authentication strength:** Not checked (checkbox).
- Require device to be marked as compliant:** Checked (checkbox).
- For multiple controls:** Require one of the selected controls (selected).

// CLOSE THE GAP

INVERT THE CONDITION

Use location to cage the bypass-prone — not to grant a free pass.



May the source be with you.

// THE FIX, IN THE PORTAL

INVERTED, IN PRACTICE

Block policy targeting excluded objects with trusted locations as the exclusion.

entra.microsoft.com → Conditional Access

GOOD - MFA Excluded location enforced

Conditional Access policy

Delete View policy information View policy impact

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Control access based on who the policy will apply to, such as users and groups, workload identities, directory roles, or external guests. [Learn more](#)

Name *

GOOD - MFA Excluded location enforced

Assignments

Users

Specific users included

Target resources

All resources (formerly 'All cloud apps')

Network NEW

Any network or location and all trusted locations excluded

Conditions

1 condition selected

Access controls

Grant

Block access

Include Exclude

☐ None

☐ All users

☒ Select users and groups

☐ Guest or external users

☐ Directory roles

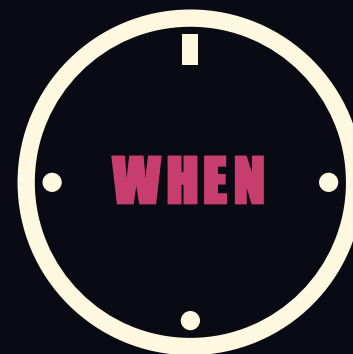
☒ Users and groups

Select

1 group

ME MFA Exclusions

// SO WHICH CONDITION FIRES



WHEN WILL THEN BE NOW?

Soon.

NEXT ATTACK PATH →

04

// SECTION 04

AND, AND, AND.*

** and you've blocked exactly one thing.*

Stack more conditions on a policy and it fires less often — not more.

// CONDITIONS, PLURAL

THREE TRUE OR NONE

"Block sign-ins where the user is risky, the sign-in is risky, AND the country is dangerous."

USER RISK**HIGH****AND****SIGN-IN RISK****HIGH****AND****COUNTRY****DANGEROUS****BLOCK FIRES** *only when all three are true.*

Each AND narrows the block. An attacker only needs to dodge one.

// FROM THE PORTAL

STACKED IN PRODUCTION

User risk + sign-in risk + country, all required to fire the block.

entra.microsoft.com → Conditional Access → Policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *

Condition Overkill ✓

Assignments

Users ⓘ

All users included and specific users excluded

Target resources ⓘ

All cloud apps

Network **NEW** ⓘ

All trusted networks and locations

Conditions ⓘ

3 conditions selected

Access controls

Grant ⓘ

Block access

Control access based on signals from conditions like risk, device platform, location, client apps, or device state. [Learn more](#)

User risk ⓘ

User risk level is the likelihood that the user account is compromised.

2 included

Sign-in risk ⓘ

Sign-in risk level is the likelihood that the sign-in session is compromised.

1 included

Insider risk ⓘ

Insider risk assesses the user's risky data-related activity in Microsoft Purview Insider Risk Management.

Not configured

Device platforms ⓘ

Not configured

Locations ⓘ

All trusted networks and locations

Client apps ⓘ

// FROM THE PORTAL

STACKED IN PRODUCTION

Device Platforms + Location Exception to fire the block.

The screenshot shows the 'Policy' configuration page in the Microsoft Entra admin center. The browser address bar shows 'entra.microsoft.com' with a breadcrumb trail 'Conditional Access' > 'Policy'. The page is divided into two main columns. The left column contains configuration sections: 'Name' (with a text box containing 'Allow Linux for Brandon'), 'Assignments' (with a link 'All users included and specific users excluded'), 'Target resources' (with a link 'All resources (formerly 'All cloud apps')'), 'Network' (with a link 'Any network or location and 1 excluded'), 'Conditions' (highlighted with a dashed border, showing '2 conditions selected'), 'Access controls', and 'Grant' (with a link 'Block access'). The right column displays risk levels: 'account is compromised.' (with a link 'Not configured'), 'Sign-in risk' (with a link 'Not configured'), 'Insider risk' (with a link 'Not configured'), 'Device platforms' (with a link '1 included'), 'Locations' (with a link 'Any network or location and 1 excluded'), and 'Client apps' (with a link 'Not configured').

entra.microsoft.com → Conditional Access → Policy

Name *

Allow Linux for Brandon

Assignments

Users or agents (Preview) ⓘ

All users included and specific users excluded

Target resources ⓘ

All resources (formerly 'All cloud apps')

Network ⓘ

Any network or location and 1 excluded

Conditions ⓘ

2 conditions selected

Access controls

Grant * ⓘ

Block access

account is compromised.

Not configured

Sign-in risk ⓘ

Sign-in risk level is the likelihood that the sign-in session is compromised.

Not configured

Insider risk ⓘ

Insider risk assesses the user's risky data-related activity in Microsoft Purview Insider Risk Management.

Not configured

Device platforms ⓘ

1 included

Locations ⓘ

Any network or location and 1 excluded

Client apps ⓘ

Not configured

// PLATFORM = STRING

IT'S JUST A USER-AGENT

The "device platform" check looks at one HTTP header. That's it.

request headers

```
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/119.0.0.0 Safari/537.36
```

SPOOFABLE

Browser dev tools. Curl. Proxies. Scripts.

HEADER ≠ DEVICE

Anything can claim to be anything.

POLICY SPRAWL

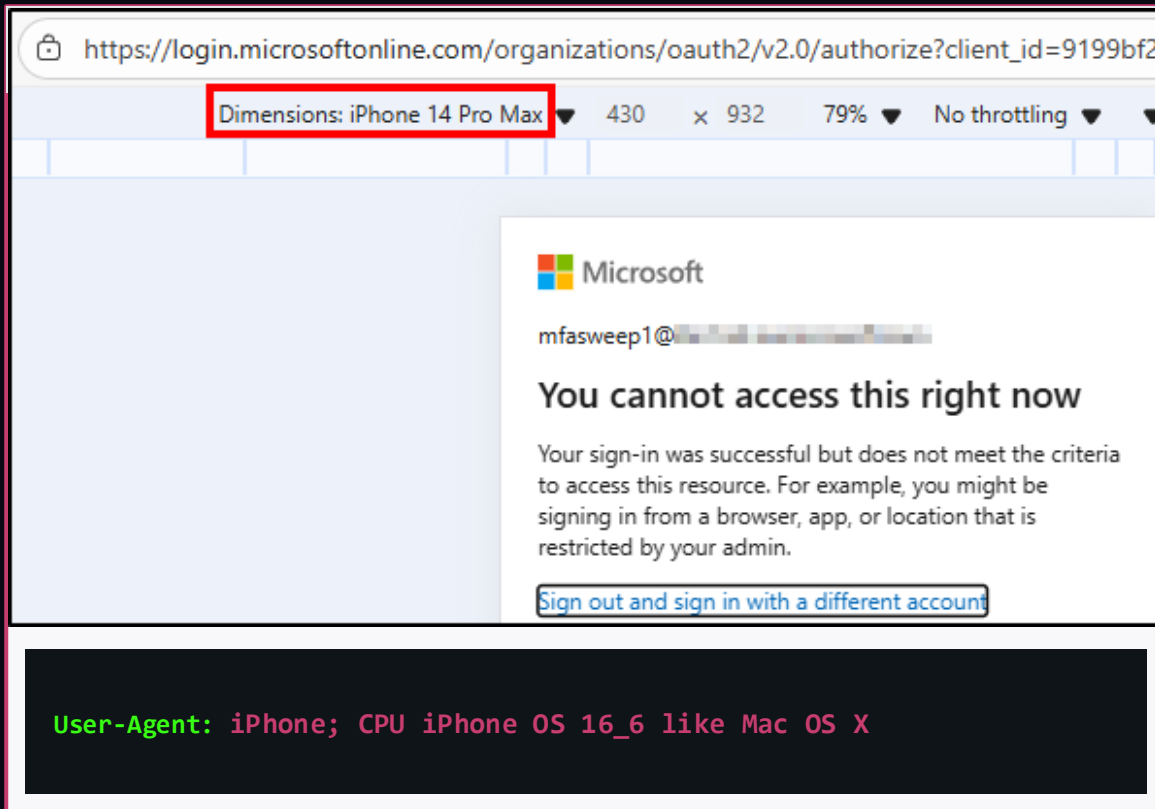
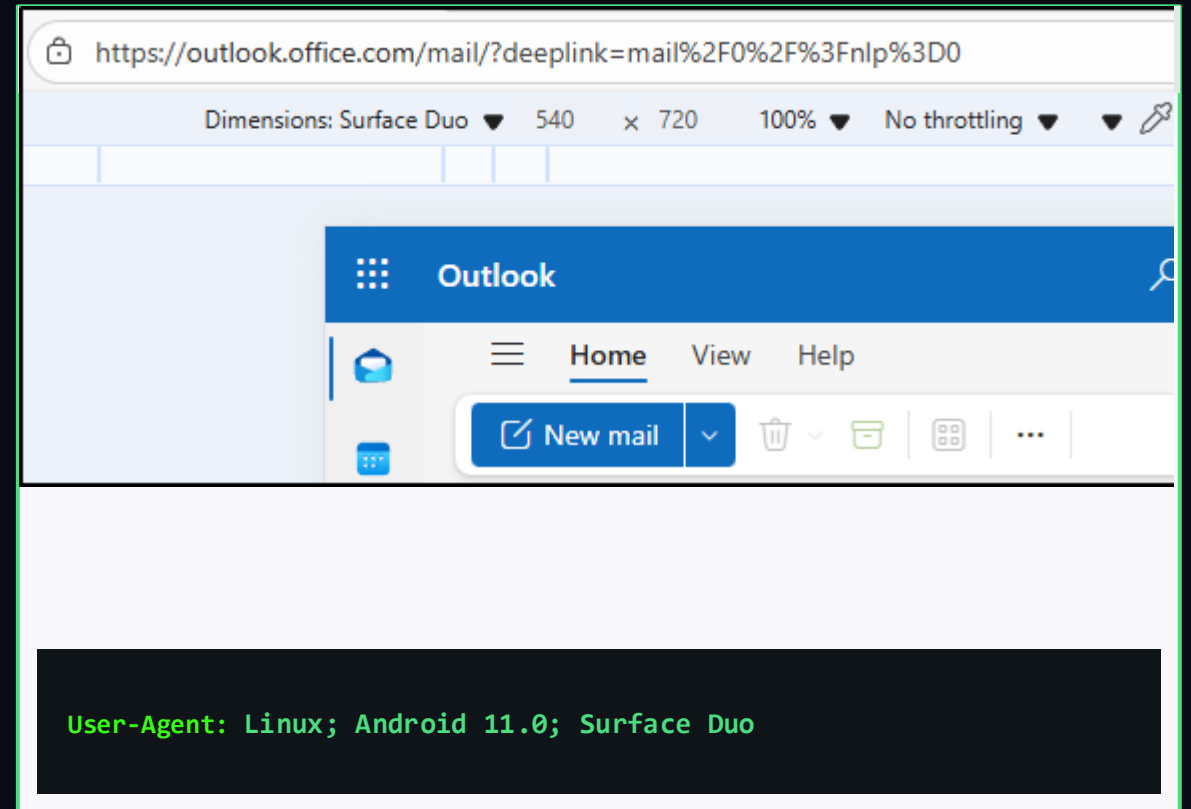
Every platform → another policy → more cracks.

Spooofable by anyone with dev tools — and by findmeaccess.

// DEMO

ONE USER-AGENT AWAY

Block policy: "No iOS, no macOS." Bypass: change the user-agent.

BLOCKED**ALLOWED**

Browser dev tools → device toolbar → switch emulation. That's the whole exploit.

// FOUR SECTIONS, ONE PATTERN

THE GAPS WE COVERED

01**POLICY SPRAWL**

200+ policies, no naming standard, no review cycle.

02**ADMIN MFA THEATER**

Built-in template covers 14 instead of 46 privileged roles.

03**TRUSTED ≠ SAFE**

Overbroad IP ranges become MFA-free zones.

04**AND-LOGIC TRAPS**

Stacked conditions + spoofable device platforms.

SO HOW DO YOU FIND THEM IN *your* TENANT?

Built-in features. Community tools. And one offensive framework worth knowing.

Modern adversaries don't break Conditional Access — they route around it.

05

// SECTION 05

DEFENDER'S TOOLKIT*** the attacker's, too.**The bubbles on these slides are supposed to look like beer...*

// SHIPPED WITH THE PORTAL

USE WHAT'S ALREADY THERE

Four features in the Entra admin center most teams underuse.

WHAT IF

Conditional Access → What If

Simulate a specific user, app, device, location — see which policies fire before you change anything.

SECURITY ALERTS

Identity Protection

Built-in alerts surface high-risk policy changes, disabled MFA grants, and stale break-glass usage.

COVERAGE TAB

Conditional Access → Overview

The Overview shows which users, apps, and platforms have at least one policy applied — and which don't.

POLICY IMPACT

Per-policy → Insights & reporting

Per-policy view of how it would have behaved against real sign-ins — counterfactual visibility.

Start here. These cost nothing and answer the easy questions first.

// WHEN BUILT-IN ISN'T ENOUGH

THE COMMUNITY DELIVERS

Free, open-source, and significantly better than spreadsheet reviews.

CA DOCUMENTER

idPowerToys

Generates clean, exportable policy documentation. Great for audits and reviews.

idpowertoys.merill.net

★ THE GOLD STANDARD

Maester

PowerShell test framework. 40+ EIDSCA + 20+ CA tests + What-If integration. Pester-based, CI-friendly. Best-in-class for posture drift detection.

maester.dev

CAP AUDIT SCRIPT

Invoke-CAPReview

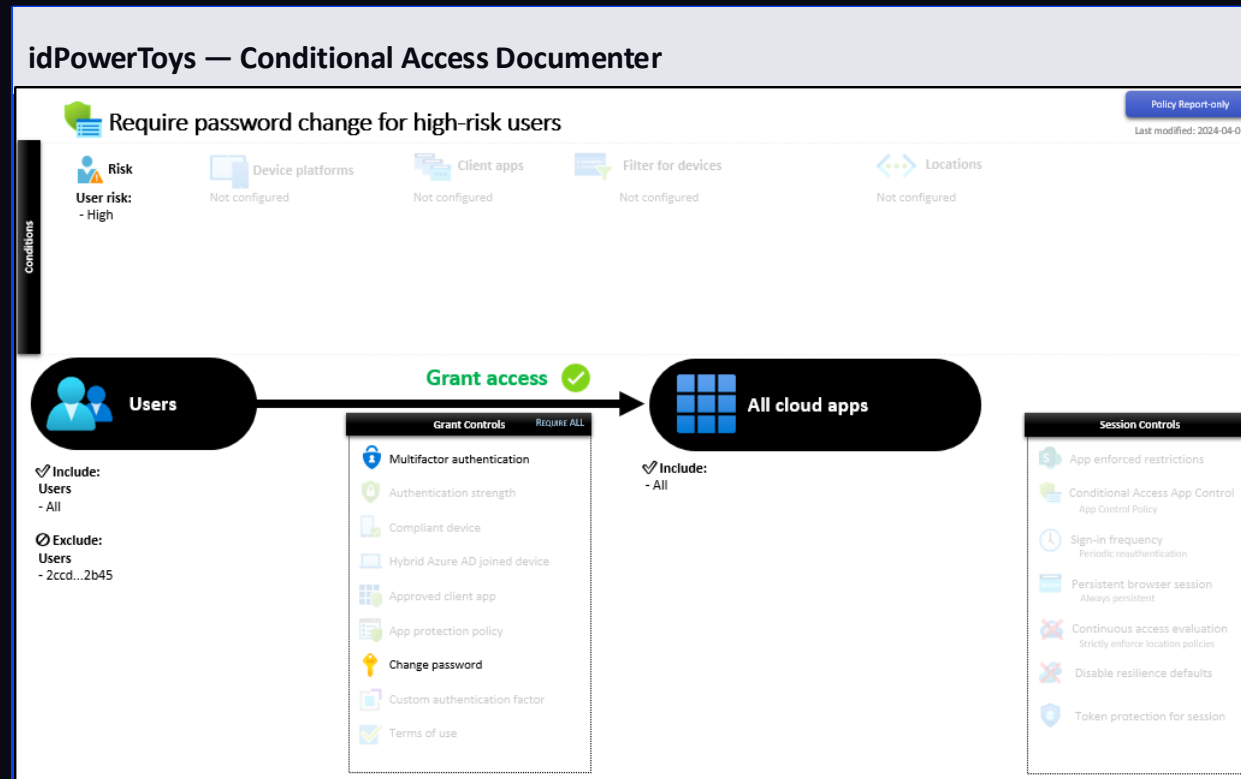
Targeted PowerShell review of CA policy posture. Quick wins for ad-hoc tenant assessments.

github.com/techBrandon/CAPs

If you only install one — install Maester. Then schedule it.

CA DOCUMENTER OUTPUT

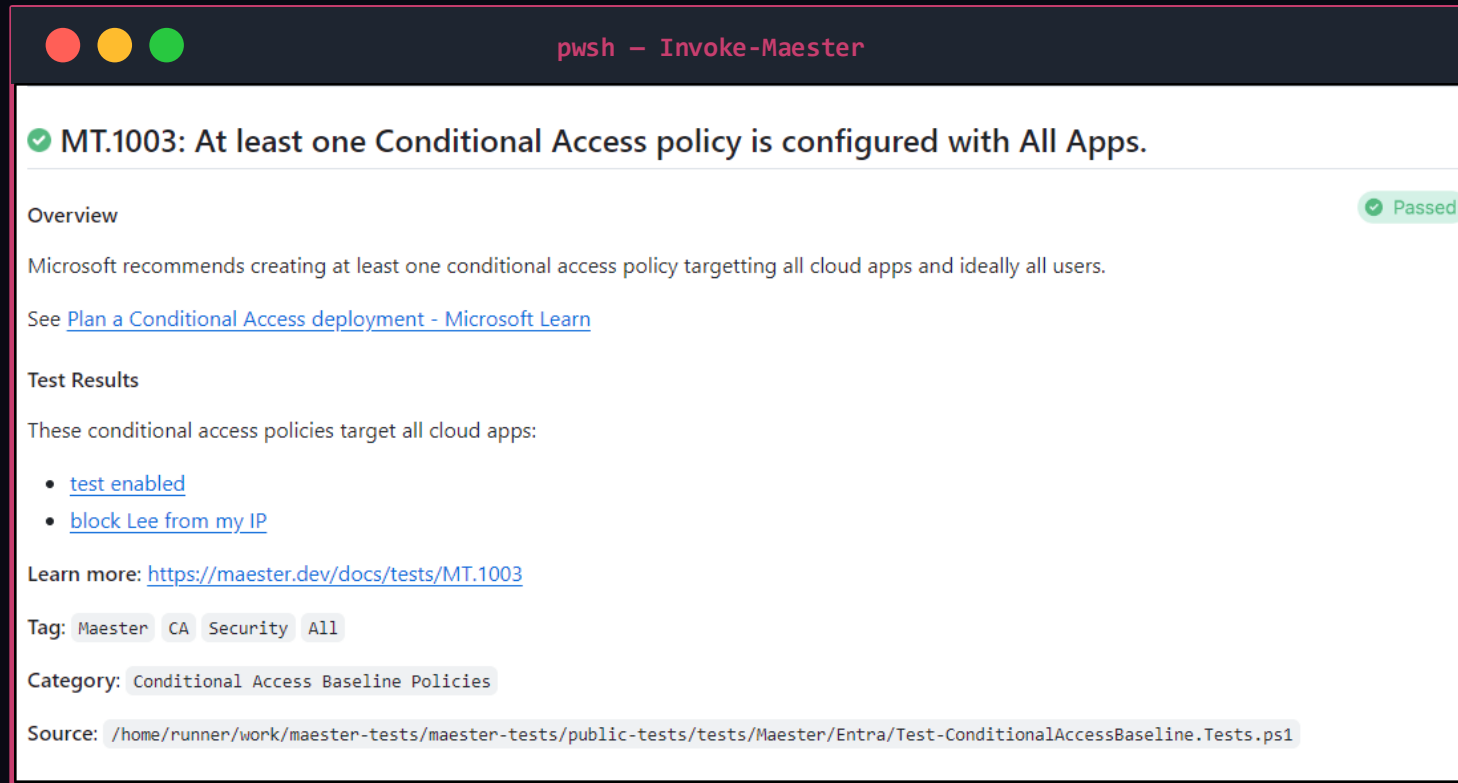
A clean export of every policy — searchable, shareable, hand-off-to-audit ready.



Cross-reference policies, exclusions, and grants. Way faster than clicking through the portal.

POSTURE DRIFT, AT A GLANCE

Pester-style test results across 60+ CA and EIDSCA checks. Run in CI; alert on regressions.



The screenshot shows a terminal window titled "pwsh - Invoke-Maester". It displays the results of a Pester test for MT.1003. The test title is "MT.1003: At least one Conditional Access policy is configured with All Apps." and it has a green checkmark icon. The test status is "Passed". The overview section states that Microsoft recommends creating at least one conditional access policy targeting all cloud apps and ideally all users. It also provides a link to "Plan a Conditional Access deployment - Microsoft Learn". The test results section shows that the conditional access policies target all cloud apps, with a list of results: "test enabled" and "block Lee from my IP". The "Learn more" section provides a link to "https://maester.dev/docs/tests/MT.1003". The "Tag" section shows "Maester", "CA", "Security", and "All". The "Category" section shows "Conditional Access Baseline Policies". The "Source" section shows the file path: "/home/runner/work/maester-tests/maester-tests/public-tests/tests/Maester/Entra/Test-ConditionalAccessBaseline.Tests.ps1".

pwsh - Invoke-Maester

✓ MT.1003: At least one Conditional Access policy is configured with All Apps.

Overview ✓ Passed

Microsoft recommends creating at least one conditional access policy targeting all cloud apps and ideally all users.

See [Plan a Conditional Access deployment - Microsoft Learn](#)

Test Results

These conditional access policies target all cloud apps:

- [test enabled](#)
- [block Lee from my IP](#)

Learn more: <https://maester.dev/docs/tests/MT.1003>

Tag: Maester CA Security All

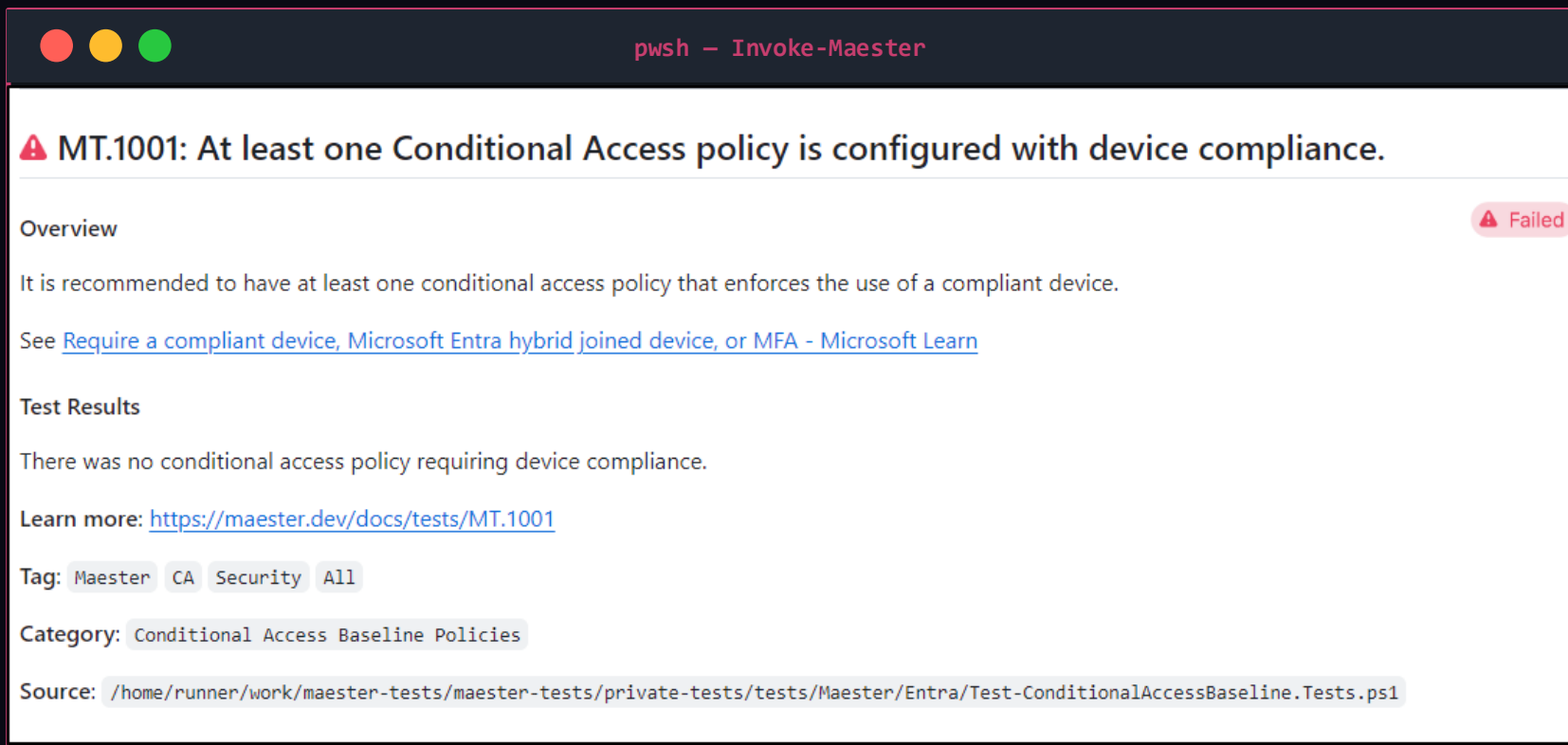
Category: Conditional Access Baseline Policies

Source: /home/runner/work/maester-tests/maester-tests/public-tests/tests/Maester/Entra/Test-ConditionalAccessBaseline.Tests.ps1

Green = posture intact. Red = a thing changed. Schedule it. Read the reds.

POSTURE DRIFT, AT A GLANCE

Pester-style test results across 60+ CA and EIDSCA checks. Run in CI; alert on regressions.



MT.1001: At least one Conditional Access policy is configured with device compliance.

Overview Failed

It is recommended to have at least one conditional access policy that enforces the use of a compliant device.

See [Require a compliant device, Microsoft Entra hybrid joined device, or MFA - Microsoft Learn](#)

Test Results

There was no conditional access policy requiring device compliance.

Learn more: <https://maester.dev/docs/tests/MT.1001>

Tag: Maester CA Security All

Category: Conditional Access Baseline Policies

Source: /home/runner/work/maester-tests/maester-tests/private-tests/tests/Maester/Entra/Test-ConditionalAccessBaseline.Tests.ps1

Green = posture intact. Red = a thing changed. Schedule it. Read the reds.

// INVOKE-CAPREVIEW

AD-HOC POSTURE REVIEW

One-shot PowerShell scan of CA policy posture. Drop, run, read.

```
pwsh - Invoke-CAPReview

Categorize Policies:

Policies that Block Legacy Authentication
Block legacy authentication SMTP
Block legacy authentication - 4real

Policies that enforce MFA for Administrators
Require multifactor authentication for admins
Require multifactor authentication for some users
Require multifactor authentication for admins - template

Policies that enforce MFA for Users
Allow Legacy app for Adele - test
Require multifactor authentication for some users
Require multifactor authentication for all users

Policies that enforce MFA for Guests
Require multifactor authentication for guest access

Policies that affect Risky Users
Require multifactor authentication for risky sign-ins
Require password change for high&Med-risk users
Require password change for high-risk users

Policies that require Approved Client or App Protection
Require approved client apps Android iOS
Require approved client apps or app protection policies - Mobile
```

```
pwsh - Invoke-CAPReview

Policies that require Approved Client or App Protection
Require approved client apps Android iOS
Require approved client apps or app protection policies - Mobile

Policies that require Device Compliance
Require compliant device for admins
Require compliant or hybrid Azure AD joined device for admins
BAD - Require MFA or Compliant or Trusted Location

Policies that restrict access by Location
Require multifactor authentication for admins
trusted IP test
block Lee from my IP

Policies that restrict access to the Admin Portal
block azure portal

Policies that require MFA for Device Join
register device
Require MFA for Device Registration

Policies that block Authentication Flows
Block Device Code Auth

Policies that target All Resources and All Users
Block legacy authentication - 4real
Require multifactor authentication for all users

Policies that secure Security Info Registration
secure registration
```

Quick wins for tenant assessments. Hand the output to your auditor.

// EXTRA: KNOW YOUR ENEMY

ROADTOOLS + DEVICE-CODE PHISH

No fake URL. No fake login page. The victim authenticates on the real Microsoft login.

01**ATTACKER**

Initiates device code flow against Microsoft.
Receives a short code (e.g. ABC123XYZ) tied to a pending auth session.

02**VICTIM**

Receives social-engineered request: "Enter this code at microsoft.com/devicelogin." The URL and page are 100% legitimate.

03**TOKENS**

Victim authenticates (MFA included).
Attacker's session receives access + refresh tokens. Done.

Why it hurts: no spoofed infrastructure to detect. The whole flow looks normal in the logs.

// STEP 01 — ATTACKER

01

INITIATE THE FLOW

The attacker requests a device code from Microsoft. Receives a short code to relay.

```
attacker terminal - device code request

(kali@kali)-[~]
$ roadrecon auth --device-code
To sign in, use a web browser to open the page https://microsoft.com/devicelogin and enter the code BMPNZQX4Q to authenticate.
```

```
victim browser - phishing invite

I'm phishing you!

Thu 8/21/2025 7:30 AM - 8:00 AM

Microsoft Teams Need help?

Join the meeting now
https://www.microsoft.com/devicelogin

Passcode: BMPNZQX4Q
```

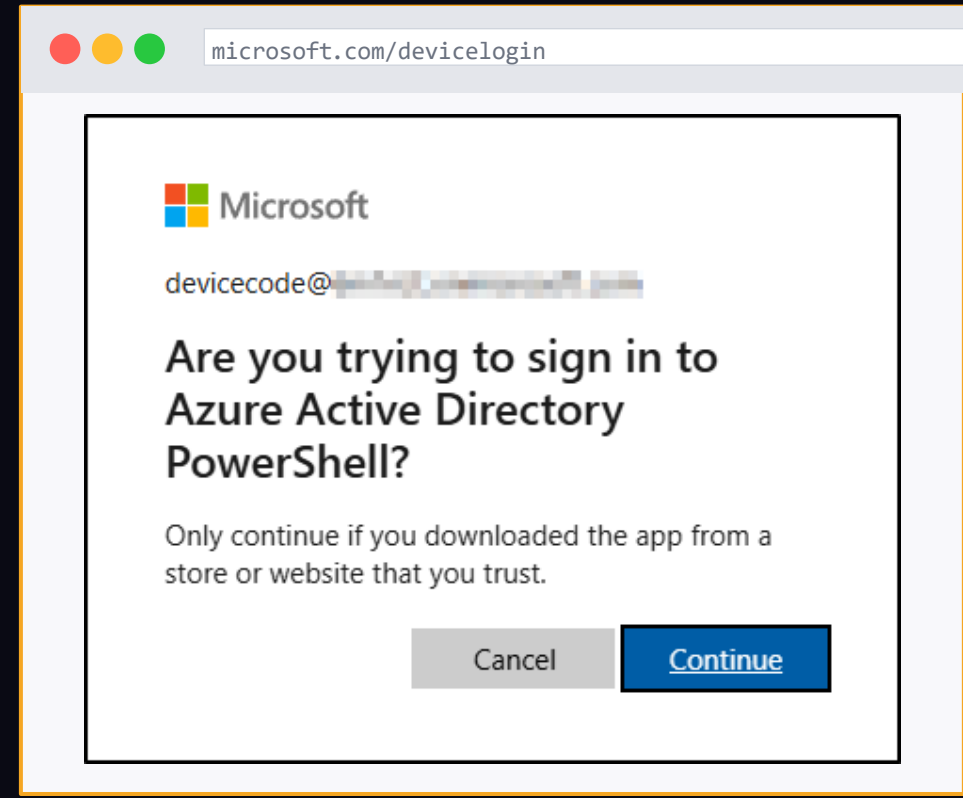
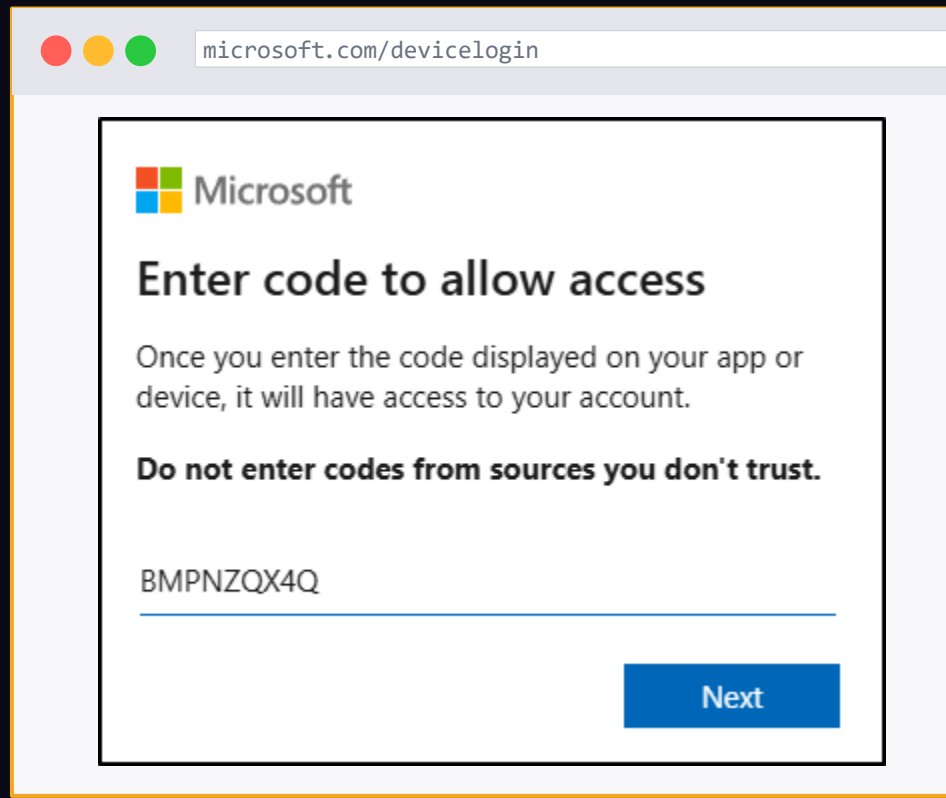
The passcode and URL both look 100% legitimate.

// STEP 02 — VICTIM

02

ENTER THE CODE

Victim visits the real microsoft.com/devicelogin and pastes the attacker's code.



Note: this is the genuine Microsoft page. No spoofing. No phishing infrastructure.

// STEP 03 — TOKENS

03

HARVEST THE TOKENS

Attacker's pending session receives access + refresh tokens. Authentication complete.

```
attacker terminal - access tokens received

(kali@kali)-[~]
$ roadrecon auth --device-code
To sign in, use a web browser to open the page https://microsoft.com/devicelogin and enter the code BMPNZQX4Q to authenticate.
Tokens were written to .roadtools_auth

(kali@kali)-[~]
$ roadrecon gather
Starting data gathering phase 1 of 2 (collecting objects)
Starting data gathering phase 2 of 2 (collecting properties and relationships)
)
ROADrecon gather executed in 4.08 seconds and issued 1088 HTTP requests.

(kali@kali)-[~]
$ roadrecon gui
* Serving Flask app 'roadtools.roadrecon.server'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on http://127.0.0.1:5000
Press CTRL+C to quit
```

Game over. The session is indistinguishable from any other legitimate sign-in.

WHAT A NORMAL USER CAN SEE

No admin privileges required. Just one phished account.

The screenshot shows the ROADrecon web application interface. The top navigation bar includes a logo and the text "ROADrecon". The left sidebar contains a list of menu items: Home, Users, Groups, Devices, Administrative Units, Directory roles, Applications, Service Principals, Application roles, and OAuth2 Permissions. The main content area is divided into several sections:

- Database Stats:**
 - Users: 59
 - Groups: 43
 - Applications: 18
 - ServicePrincipals: 239
 - Devices: 1
 - Administrative Units: 0
- Directory settings:**
- Tenant information:**
 - Name: MSFT
 - Tenant ID: 2b914474-447e-4...
 - Syncs from AD: Yes
 - View Raw
- Authorization Policy:**
 - Self-service password reset enabled: Yes
 - MSOnline PowerShell blocked: No
 - Default user role permissions:
 - allowedToCreateApps: No
 - allowedToCreateSecurityGroups: Yes
 - allowedToReadOtherUsers: Yes
 - Application consent settings:
 - Resource specific consent for Teams: Yes
 - Resource specific consent for chats: Yes
 - User self-consent is disabled
 - Guest access settings: Restricted access

WHAT YOU PULL BACK:

- Tenant configuration
- Every user, group, and role assignment
- Every app registration & service principal
- Device inventory, OS, compliance state

WHAT THE ATTACKER SEES

The CA policies plugin renders every policy as readable HTML

THE ONE-LINER:

```
$ roadrecon plugin policies → ca_policies.html
```

PARSED

GUIDs resolved to names. Conditions, exclusions, and grants laid out in one view.

STATIC HTML

One file. Self-contained. Searchable. Diffable in source control.

READABLE

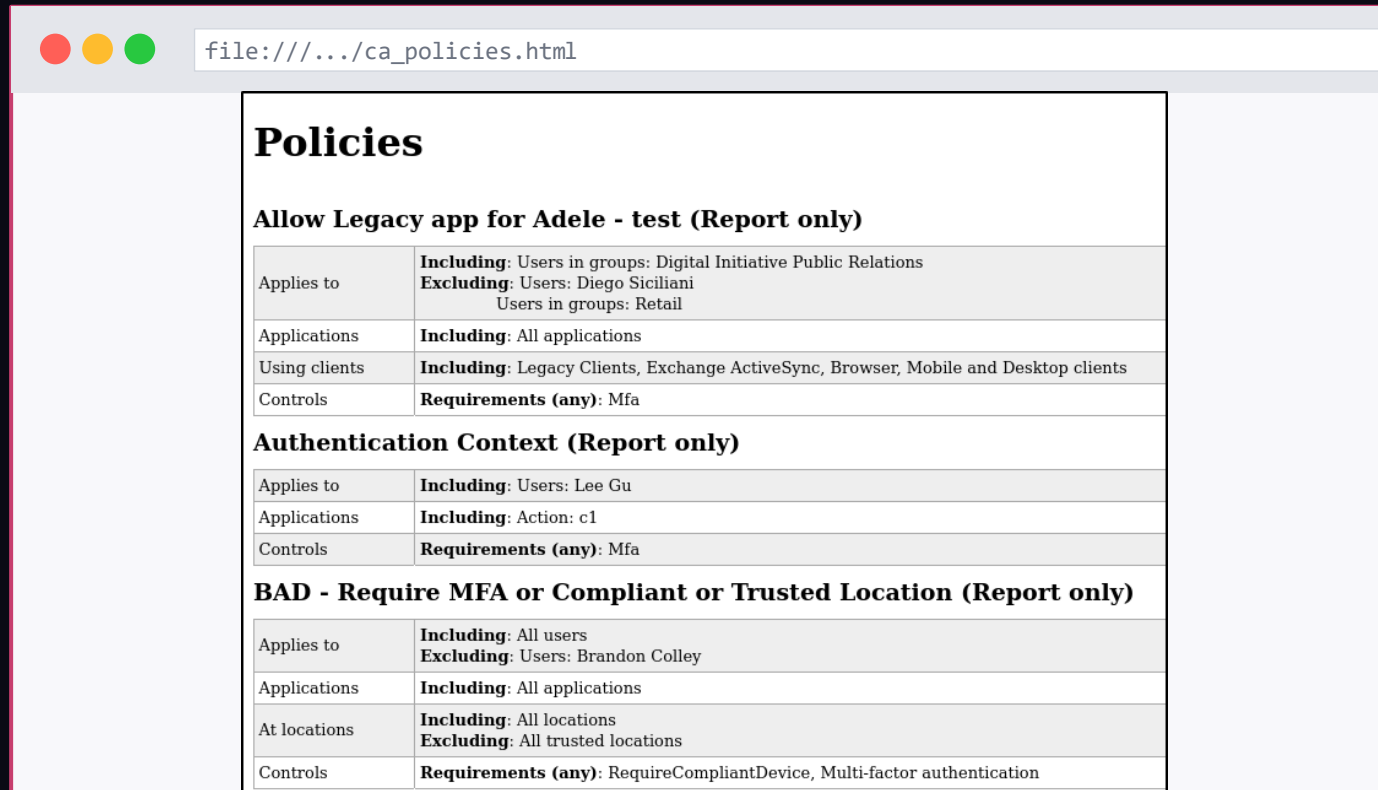
The format an attacker would consume — and what your CA posture looks like from the outside.

CA policies aren't visible to users in the portal — but the API returns them anyway.

// THE OUTPUT

CA_POLICIES.HTML

Every policy in your tenant — laid out in one searchable page.



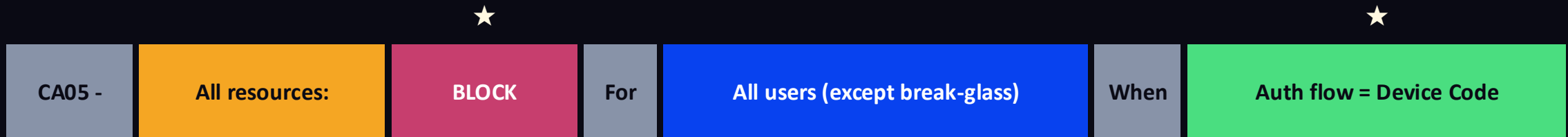
Policies	
Allow Legacy app for Adele - test (Report only)	
Applies to	Including: Users in groups: Digital Initiative Public Relations Excluding: Users: Diego Siciliani Users in groups: Retail
Applications	Including: All applications
Using clients	Including: Legacy Clients, Exchange ActiveSync, Browser, Mobile and Desktop clients
Controls	Requirements (any): Mfa
Authentication Context (Report only)	
Applies to	Including: Users: Lee Gu
Applications	Including: Action: c1
Controls	Requirements (any): Mfa
BAD - Require MFA or Compliant or Trusted Location (Report only)	
Applies to	Including: All users Excluding: Users: Brandon Colley
Applications	Including: All applications
At locations	Including: All locations Excluding: All trusted locations
Controls	Requirements (any): RequireCompliantDevice, Multi-factor authentication

This is what an attacker walks away with from one phished account. Worth understanding what they get.

// CLOSE THE GAP

BLOCK THE FLOW

Microsoft's own recommendation: block device code flow wherever possible.



WHY

Device code is a high-risk flow. Microsoft's own guidance: block by default.

ROLLOUT

Start in report-only. Filter sign-in logs for device-code auth before enforcing.

EXCEPTIONS

Conference rooms, signage, legacy CLI tooling — narrow allow-lists only.

May the source be with you.

// WHAT TO REMEMBER

ROUTE AROUND IT, NOT THROUGH IT.

01

ATTACKERS DON'T BREAK CA

Every attack path covered routes around the control, never through it. Stop thinking about CA as a wall — think exit doors.

02

MISCONFIGS COMPOUND

Naming chaos hides role gaps. Role gaps create trusted-location bypasses. Stacked conditions tie it all together. They feed each other.

03

TEST. AUDIT. SCHEDULE.

What If for one-offs. Maester for posture drift. ROADrecon for the attacker's view. Run them on a cadence — not once a year.

Modern adversaries don't break Conditional Access — they route around it.

// FURTHER READING

REFERENCES

Every claim, every tool, every doc.

INCIDENTS & RESEARCH

Sygnia — Stryker / Handala case

sygnia.co/threat-reports-and-advisories

TrustedSec — Privileged role tiers

trustedsec.com/blog

Volexity — Nearest Neighbor Attack

[Volexity.com/blog](https://volexity.com/blog)

MICROSOFT DOCS

Conditional Access What If

[learn.microsoft.com → what-if-tool](https://learn.microsoft.com/what-if-tool)

Block device code flow

[learn.microsoft.com → auth-flows](https://learn.microsoft.com/auth-flows)

"Require MFA for admins" template

[learn.microsoft.com → admin-mfa](https://learn.microsoft.com/admin-mfa)

Privileged role definitions

[learn.microsoft.com → privileged-roles](https://learn.microsoft.com/privileged-roles)

TOOLS

★ Maester

maester.dev

idPowerToys (CA Documenter)

idpowertoys.merill.net

ROADtools

github.com/dirkjanm/ROADtools

FindMeAccess

github.com/absolomb/FindMeAccess

Invoke-CAPReview (script)

github.com/techBrandon/CAPs



// LET'S TALK

QUESTIONS?

Or share your war stories. The bar is right there.

FIND ME

@techBrandon

<https://www.linkedin.com/in/techbrandon/>

<https://github.com/techBrandon>

Contact@BNRconsulting.net

// END OF TRANSMISSION

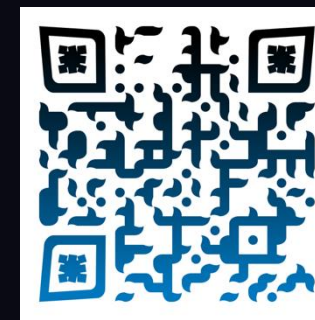
HTH'26

THANKS FOR LISTENING.

May the Schwartz be with you.

@techBrandon

Contact@BNRconsulting.net



slides + tools